TFG · SONDA PASIVA DE DETECCIÓN PQC

La patente, en limpio

Método y dispositivo para el análisis de la seguridad postcuántica en una red de comunicaciones

Pablo Marugán Bastante · GITST, EPS-UAM · Tutor: Jorge E. López de Vergara | **Tutoría del miércoles 14/10/2026**

1. Cómo se lee el documento

Una patente se lee en orden inverso al que está escrita: lo que define legalmente el invento son las **reivindicaciones**; todo lo anterior es contexto y ejemplos no limitativos.

Parte	Págs.	Para qué sirve
Objeto y antecedentes	1–3	El problema y el estado del arte
Sumario	3–9	El método en abstracto
Descripción detallada	9–23	Módulos, modos de operación y ejemplos concretos
Reivindicaciones	**24–27**	**Lo que realmente se protege**
Resumen	28	Un párrafo

Son **15 reivindicaciones**: las 1–11 cubren el método, las 12–14 el dispositivo y la 15 el programa de ordenador. La 1, la 12 y la 15 son independientes; el resto cuelgan de ellas.

2. El método: cuatro pasos

La reivindicación 1 es el núcleo. Todo lo demás son variantes de estos cuatro pasos:

Paso	Contenido
a)	Obtener mensajes transmitidos por los equipos de la red
b)	Identificar los algoritmos criptográficos usados en el intercambio de claves **y/o** en la firma de certificados, y determinar si son postcuánticos
c)	Clasificar como **inseguros** los equipos que no ofrecen ni aceptan PQC
d)	Generar un listado de los equipos clasificados como inseguros

La **reivindicación 2** desdobla el paso a) y es la que define mi hueco:

- **a1)** Capturar el tráfico → **modo pasivo** → **mi TFG**
- **a2)** Enviar solicitudes de establecimiento → **modo activo** → TFG de Roberto Sanz

Dice "**y/o**", luego hacer solo a1) está plenamente dentro de la reivindicación. Lo mismo con el "y/o" del paso b): analizar únicamente el intercambio de claves, sin tocar certificados, también está cubierto.

La **reivindicación 9** añade un tercer estado: **potencialmente inseguro**, para los equipos que soportan PQC pero *además* admiten algoritmos precuánticos.

3. El aparato: cuatro módulos (figura 1)

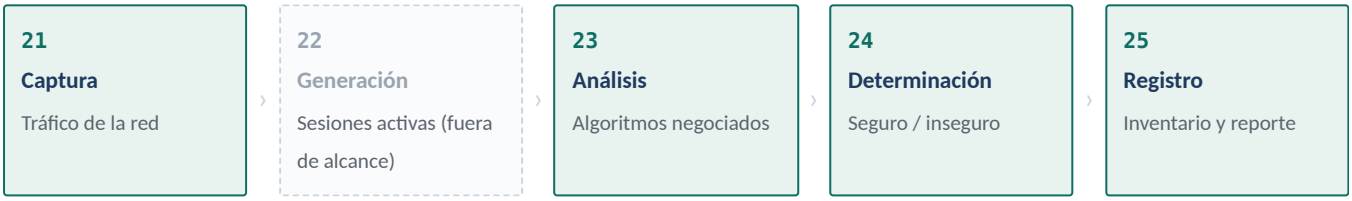
Esta es, en la práctica, la arquitectura del programa que tengo que escribir.

Módulo	Qué hace	¿Me toca?
(1) Captura de tráfico	TAP, divisor óptico, puerto SPAN/espejo, o interfaz en modo promiscuo / monitor	**Sí**
(2) Generación de sesiones seguras	Abre conexiones de prueba ofreciendo algoritmos PQC	No — es el TFG de Roberto
(3) Análisis de protocolos y certificados	Identifica los algoritmos negociados y consulta la BD de identificadores	**Sí (solo TLS / claves)**
(4) Inventariado y reporte	Mantiene el registro de equipos inseguros y genera informes o alertas	**Sí**

MI TFG DESCRITO POR LA PROPIA PATENTE (PÁG. 17)

> *"En otra realización, el aparato constaría solo del módulo de captura de tráfico (y no del módulo 2), por lo que todo el tráfico analizado provendría de tráfico capturado, es decir, siempre funcionaría en modo pasivo."*

Flujo del método (figura 2)



☐ Pasos que implemento en mi TFG. Mi flujo es 21 → 23 → 24 → 25.

4. Los cinco detalles que condicionan el diseño

4.1. Qué filtrar — ya viene especificado (págs. 15–16)

La patente indica capturar solo los paquetes de los mensajes de negociación, para reducir la carga de análisis:

- **Mensajes:** `ClientHello`, `ServerHello`, `IKE_SA_INIT`, `SSH_MSG_KEX_INIT`
- **Puertos:** 443/TCP, 443/UDP (QUIC), 500/UDP, 22/TCP

Como mi enunciado se limita a TLS, el filtro BPF de partida es el puerto 443/TCP. IKE, SSH y QUIC quedan como trabajo futuro, y está bien justificado porque la patente los contempla.

4.2. Los certificados no son analizables en pasivo — y lo dice la patente (pág. 13)

> *"En el caso en el que los certificados se transmitan cifrados [...] no se podrá llevar a cabo este análisis de los certificados en el modo pasivo. Pero [...] sí se puede llevar a cabo en el modo activo al contar en ese caso con las claves utilizadas en la sesión."*

En TLS 1.3 el mensaje `Certificate` va siempre bajo claves de handshake, así que esto no es un caso particular sino la norma. **Mi sonda analiza intercambio de claves, no firmas**, y la patente respalda esa acotación.

4.3. La base de datos de identificadores es un módulo con entidad propia (reiv. 8)

Una BD, interna o externa, que asocia cada identificador a pre/postcuántico y es actualizable desde un servidor securizado. La patente da dos ejemplos:

Identificador	Algoritmo	Ámbito
`0x11EC`	X25519MLKEM768	Código IANA de TLS — intercambio de claves
`1.3.6.1.4.1.2.267.7.6.5`	Dilithium3	OID — firma de certificados

Para mí es la tabla que mapea valores de `NamedGroup` a su veredicto. **Conviene no hardcodearla**: un fichero externo cargable cubre la reivindicación 8 y la indicación de la página 18 sobre actualizar el listado.

4.4. Los campos del inventario están especificados (reiv. 10)

Esta es la estructura de salida; no hay que inventarla:

- Si se trata de un cliente o un servidor
- Dirección IP del equipo
- Protocolo y puerto usado
- **Huella del protocolo** — la patente la llama "JA+": la familia JA3/JA4, que identifica *qué* implementación cliente o servidor interviene
- Tipo de vulnerabilidad detectada
- Si afecta al intercambio de claves o a la firma digital de los certificados
- Fecha de inclusión en el registro
- Si se detectó en modo pasivo o activo

Los dos últimos campos son reveladores: el de fecha habilita el "uso recurrente" (pág. 14) y el de modo está pensado para cuando las dos sondas se fusionen en el modo híbrido.

4.5. El modo híbrido es la unión de los dos TFGs (pág. 16)

El modo activo hace falta "para evitar aquellos casos en los que todavía no exista tráfico de red generado de forma natural"; el pasivo permite analizar "tráfico de clientes sobre los que el modo activo no tiene visión directa". Es exactamente la relación entre el trabajo de Roberto y el mío, y merece mencionarse en la tutoría.

5. Asimetría cliente / servidor en modo pasivo

Cruzando la reivindicación 9 con el funcionamiento real de TLS 1.3 aparece un resultado que no está escrito en la patente y que conviene llevar planteado:

Equipo	Clasificación	¿Determinable?
Cliente	Inseguro	**Sí, con una sola conexión.** La extensión `supported_groups` (10) del ClientHello lista toda su capacidad: si no aparece ningún grupo PQC, es inseguro.
	Potencialmente inseguro	**Sí, con una sola conexión.** Si en `supported_groups` aparecen grupos PQC *y además* clásicos.
Servidor	Inseguro	**Sí, con una sola conexión**, pero **solo si el cliente ofreció PQC** y aun así el servidor eligió un grupo clásico.
	Potencialmente inseguro	**Requiere agregación.** El ServerHello dice qué eligió, no qué habría aceptado: hay que verlo elegir PQC en una conexión y clásico en otra.
	Indeterminado	Si el cliente no ofreció PQC, esa conexión **no aporta nada** sobre el servidor.

> **CONSECUENCIA DE DISEÑO**
>
> "Indeterminado" tiene que ser un **estado de primera clase**, nunca un alias de "inseguro". Es el error que comete el resumen de la sonda de Roberto (colapsa `Error` en `Not supported`), y en pasivo hay dos motivos distintos para no poder concluir: no ver el handshake completo, y que el cliente nunca ofreciera PQC. Además, el veredicto de servidor necesita **estado persistente por servidor**, no solo por conexión.

6. Lo que ya está desfasado en la patente

Elemento	Situación actual
Dato de adopción Cloudflare, marzo 2024: 2 % de las conexiones TLS con PQC, previsión del 10 % a final de año	Roberto midió ~66 % en el top 100 en enero de 2026. En mis pruebas, `wikipedia.org` ha migrado desde entonces. La patente describe un escenario de hace dos años.
OID de Dilithium3 `1.3.6.1.4.1.2.267.7.6.5`	Pertenece al arco experimental previo a la estandarización. ML-DSA ya tiene OIDs propios bajo el arco de NIST. No me afecta porque los certificados quedan fuera de alcance, pero conviene saberlo.
Estado del arte citado tlsscan (pasivo) y NMAP (activo)	Merece la pena mirar **tlsscan**: es el competidor directo del modo pasivo y sirve para argumentar qué aporta mi sonda que él no.

7. Puntos a plantear en la tutoría

- **Confirmar el alcance:** solo TLS, solo intercambio de claves, certificados fuera (respaldado por la pág. 13 de la patente).
- **La asimetría cliente/servidor** y cuál de las tres opciones de clasificación de servidores prefiere: descartar conexiones no informativas, acumular estado por servidor, o añadir el estado "indeterminado".
- **Alcance de la huella JA4:** la reivindicación 10 la incluye como campo del inventario. ¿Entra en el TFG o se deja como trabajo futuro?
- **IPv6 y QUIC:** confirmar que quedan fuera del alcance inicial.
- **Dato administrativo:** este PDF contiene solo descripción, reivindicaciones y resumen, sin portada, así que **no aparecen ni el número de solicitud ni los inventores**. Hay que pedírselos a Jorge para poder citar la patente correctamente en la memoria.